DOCUMENT · SOURCE DOCS/PORTFOLIO/02-NEXUSOS-PORTFOLIO-SUMMARY.CORRECTED.MD

NexusOS

A multi-tenant business operations platform where identity, authorization, and tenant isolation are platform infrastructure — with live CRM, HR, finance, inventory, projects, reporting, and gated Stripe/AI integrations.

01 / OVERVIEW

Overview

NexusOS unifies business capabilities behind one React application shell and one FastAPI service: shared authentication, RBAC with database re-validation, and application-level tenant isolation. Product modules are implemented as APIs and UI on that foundation. PostgreSQL row-level security is intentionally deferred.

02 / MY ROLE

My Role

Sole engineer — architecture, backend, frontend, data model, security controls, design system, tests, and CI.

03 / KEY ENGINEERING HIGHLIGHTS

Key Engineering Highlights

Tenant scope is derived after sign-in. Authenticated APIs do not take a client-chosen tenant id. Company identity comes from the caller's stored user record on every protected request.

Authorization is re-derived from the database. Roles and permissions are loaded fresh on protected requests and fail closed for suspended users or deactivated tenants.

Refresh-token reuse is treated as compromise. Refresh tokens rotate against server-side sessions; replaying a spent token revokes that user's sessions and records an audit event.

Isolation is application-level plus relational constraints. Tenant-scoped repositories filter by `company_id`, and composite foreign keys block cross-tenant relationships. PostgreSQL RLS is not implemented.

Layered request security. CORS allowlisting, security headers, Redis-backed rate limiting on credential endpoints (fails open if Redis is unavailable), and a trusted-proxy boundary for client IP resolution.

Integrations are env-gated. Stripe platform billing / Connect and the OpenAI assistant are implemented in code and remain inactive until configured.

04 / TECHNOLOGY

Technology

Frontend — React 19, TypeScript, Vite, React Router, TanStack Query, Zustand, React Hook Form, Tailwind CSS, Radix UI, Recharts, Stripe.js

Backend — Python 3.12, FastAPI, Pydantic v2, SQLAlchemy 2.0 async, Alembic, Argon2, PyJWT, structlog

Data — PostgreSQL via asyncpg, Redis for rate-limit counters

Tooling — Docker Compose, GitHub Actions CI, pytest, Vitest, ruff, TypeScript

External (ops) — typically Vercel + Railway; Cloudflare may provide DNS/TLS/WAF — dashboard settings are not proven from the repository alone

05 / STATUS

Status

Implemented — multi-tenant identity, authentication lifecycle, RBAC with database re-validation, security middleware, design system/shell, and product modules: CRM, HR, finance, inventory, projects/tasks, reports, dashboard metrics, notifications, settings.

Implemented, partially verified — AI assistant (requires `OPENAI_API_KEY`), Stripe billing/Connect (requires enable flags and secrets), production HSTS / trusted-proxy / edge WAF settings.

Planned — PostgreSQL row-level security as defense-in-depth.

Evidence: repository `docs/NEXUSOS_MASTER_AUDIT.md` and `docs/IMPLEMENTATION_STATUS.md`.